CONTENT DISCOVERY

TryHackMe Learning & Practical Report

Prepared by	Belal Rabea Khalifa
Program	IqraSec Academy, WAPT Internship (Cohort 02), Phase 1
Task	2. Recon & Enumeration
Platform	TryHackMe
Room	Content Discovery (https://tryhackme.com/room/contentdiscoveryx)
Focus	manual discovery, headers, page source, OSINT, Gobuster
Completion	100% (all 8 tasks)
Date	October 2026

1. Objective

Learn how to find hidden content of a web application using manual techniques, OSINT, and automated tools (Gobuster), and practice it on the room's target.

2. Concept / Understanding

- **robots.txt:** a file that tells crawlers which paths they should or should not visit. It is only a guideline, not a security control, and it can reveal paths the owner wants to hide.
- **sitemap.xml:** an XML file that lists the pages of the site. It is useful to map the structure of the application.
- **HTTP headers:** the server response can show metadata like *Server* and *X-Powered-By*, which reveal the web server, the framework, and sometimes the version.
- **Page source:** HTML comments, links and script files can reveal the framework name and version, and hidden pages.
- **OSINT:** Google dorking, the Wayback Machine (old versions of pages), GitHub repositories and cloud storage like S3 buckets can leak old pages, credentials or exposed files.
- **Gobuster:** an automated tool that guesses names from a wordlist. Mode *dir* finds directories and files, *dns* finds subdomains, *vhost* finds virtual hosts.
- **Subdomains vs virtual hosts:** a subdomain is resolved by a DNS record (blog.example.thm). A virtual host is handled by the web server itself, using the Host header.
- **Default credentials:** admin panels of frameworks often have default usernames and passwords. If they are not changed, anyone can log in.

3. Practical Work

I finished all 8 tasks of the room. On the room's target (an "Acme IT Support" website), I did the following:

#	Step	What I found
1	Opened the page source (view-source) of the home page	Links to /news, /contact, /customers and /secret-page. An HTML comment at the bottom says the page was generated by **THM Framework v1.2** and gives a URL.
2	Ran `curl http://10.113.174.246/ -v` from the AttackBox	Response headers: **Server: nginx/1.18.0 (Ubuntu)**, **X-Powered-By: THM-Framework**, and the **X-FLAG** header with the first flag.

3	Opened the framework's admin login page (/thm-framework-login) and logged in as **admin** with the default credentials	The admin portal page showed the second flag.

The two answers were accepted as correct in the room.

4. Tools Used

- TryHackMe AttackBox
- Web browser (view-source)
- curl (verbose mode, -v)

5. Evidence

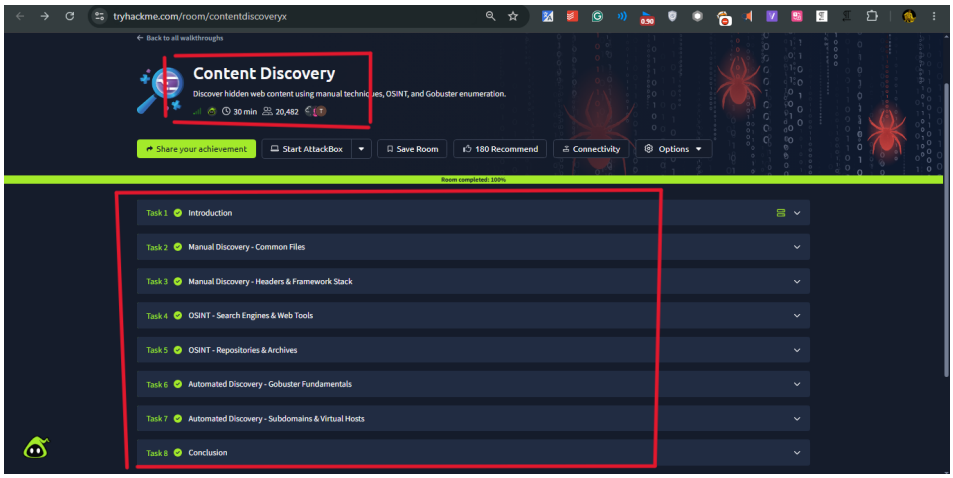


Figure 1: Content Discovery room page, 100% completed, all 8 tasks done.



Figure 2: page source of the target. The comment at the bottom (highlighted) shows the framework name and version.

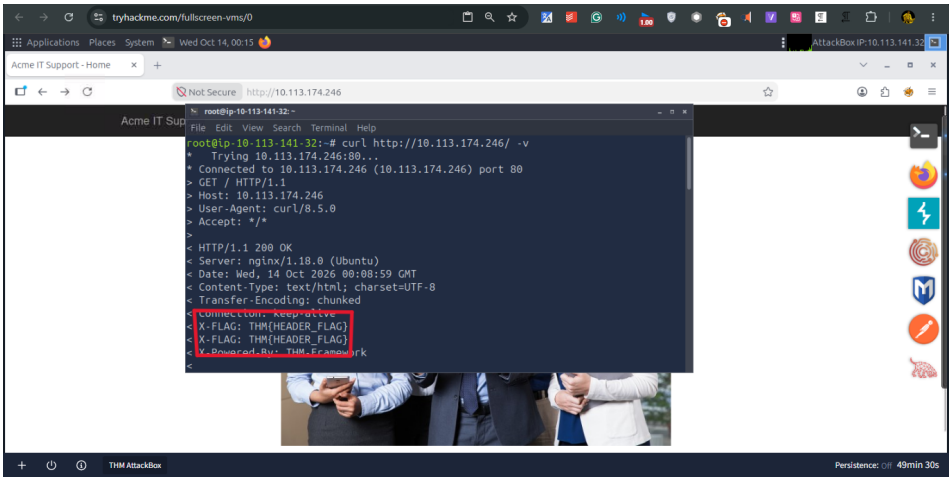


Figure 3: curl -v output. Server, X-Powered-By and the X-FLAG header are visible.

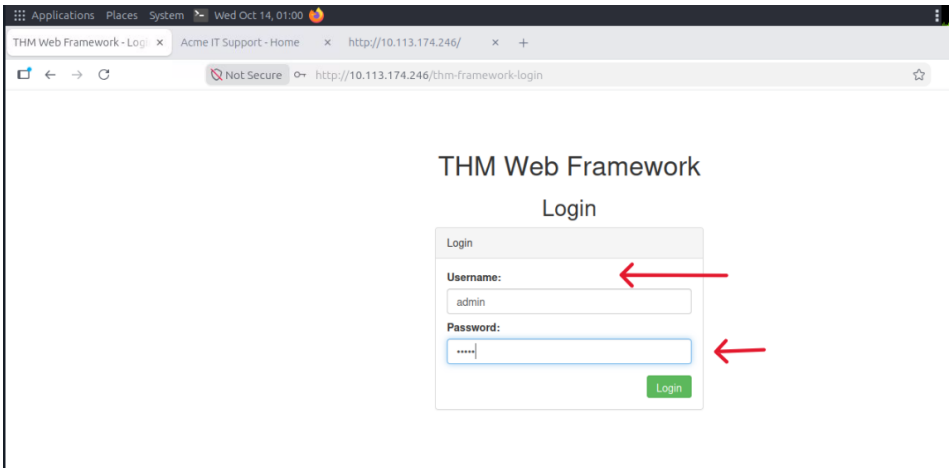


Figure 4: the framework's admin login page, logging in as admin.

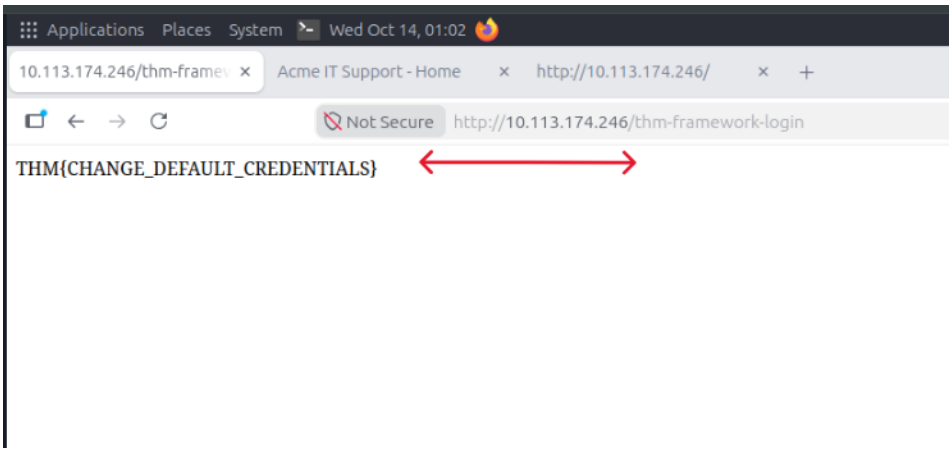


Figure 5: the admin portal page showing the flag.

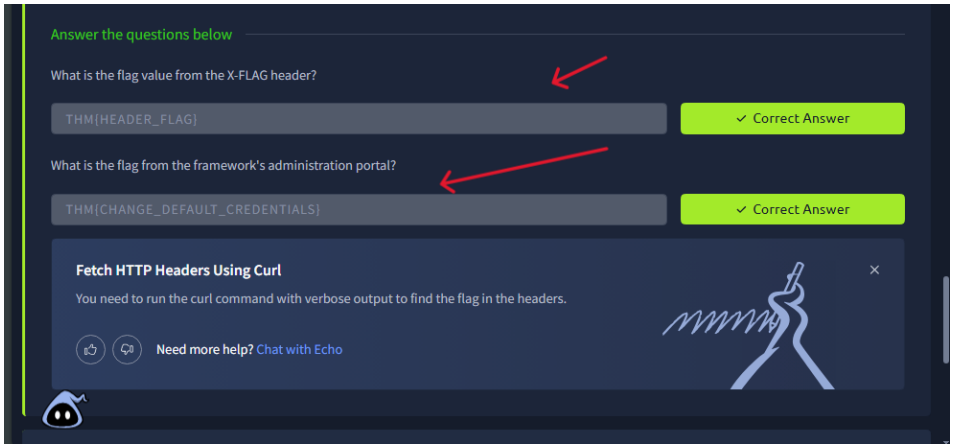


Figure 6: both answers accepted as correct in the room.

6. Result

Completed the room 100%. Using the page source and the response headers, I identified the web server (nginx 1.18.0) and the framework (THM Framework v1.2), found its admin portal, and logged in with the default credentials. Both flags were accepted.

7. Key Learnings

- The page source and the response headers can reveal the technology and version of an application, which helps an attacker find known weaknesses.
- Default credentials on an admin portal are a serious risk. They must be changed after installation.
- robots.txt, sitemap.xml, OSINT sources and Gobuster help to find hidden pages and subdomains.
- Gobuster uses different modes: dir for paths, dns for subdomains, vhost for virtual hosts.
- To protect: remove version information from headers and comments, restrict the admin portal, and do not keep default credentials.